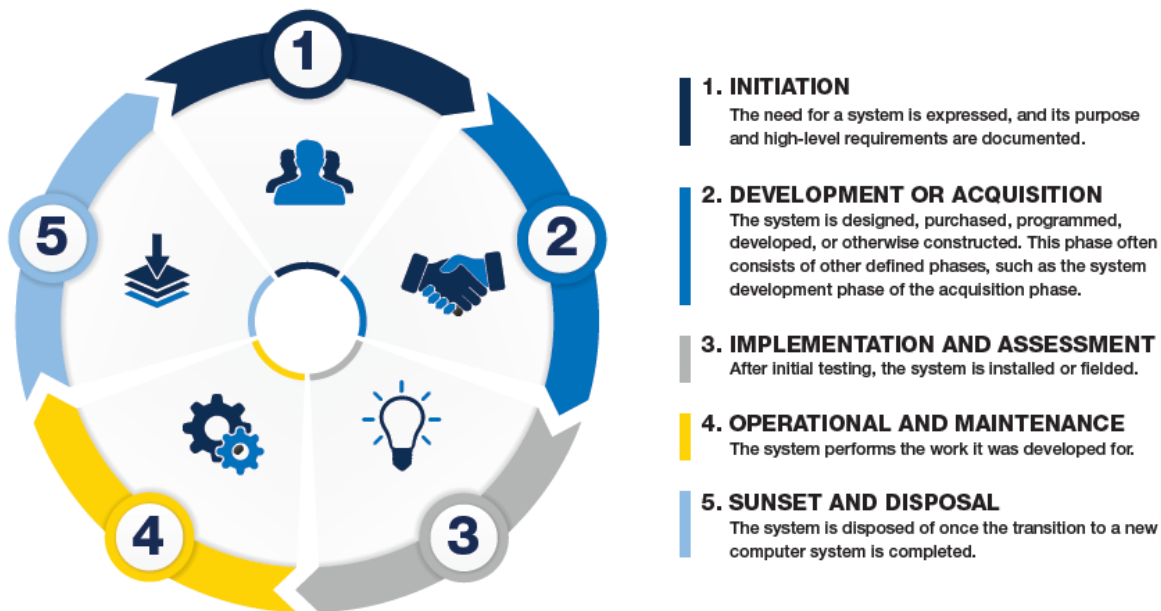


Effective management understands the SDLC phases and the actions needed in each phase. The phases may be divided differently depending on the entity, the project type and characteristics, and the SDLC used. Management should identify the actions and assign responsibility and accountability for completing those actions. Key stakeholders of the system or component being developed or modified should monitor progress in each phase including the output of each phase. This involvement mitigates the risk that the system or component does not deliver the requested functionality. Management should maintain confidentiality, integrity, availability, and resilience throughout all phases of the SDLC.

An entity that defines its SDLC phases helps ensure transparency and accountability to, and agreement and system or component acceptance by, the stakeholders. Figure 4 illustrates the five general SDLC phases (Initiation, Development or Acquisition, Implementation and Assessment, Operations and Maintenance, and Sunset and Disposal) identified by NIST.¹³⁷

Figure 4: NIST Example of a System Development Life Cycle



IV.O.1(a) *Initiation*

The initiation phase begins when entity personnel identify an opportunity to build, buy, or modify a system or component and formally seek approval with an IT project request. The project team should describe the IT project's purpose, identify expected benefits, and explain how the proposed system or component supports the entity's objectives. The project team should summarize the confidentiality, integrity, availability, resilience, and legal and regulatory

¹³⁷ Refer to NIST Information Technology Laboratory (ITL) Bulletin, "[The System Development Life Cycle \(SDLC\)](#)."

requirements. They should identify alternative solutions and justify their recommended solution. Through IT project request development, stakeholders should gain a common understanding of the project's objectives, security considerations, and risk management planning to mitigate the risk of project failure.

During the IT project request review, management can accept, reject, or request changes before it allocates resources. Management can also commission a formal feasibility study to inform its decision. If the IT project request is to modify an existing system, management should consider performing a security impact analysis¹³⁸ to identify any negative impact to existing security controls. Such a security impact analysis may be performed as part of the feasibility study.

Planning, particularly in the project's early stages, should help the project team and management coordinate development activities and manage risks effectively. Planning helps the project team and management add or clarify the project's specific activities, resources, costs, and benefits. A critical part of planning is to coordinate stakeholder discussions to identify and document as many of the entity's functional, security, and network requirements as possible.

Primary items entity personnel typically include in planning consist of the following:

- Responsibilities of third-party service providers, internal audit, information security, and IT staff.
- Entity SDLC processes.
- SDLC phase acceptance criteria including review and approval procedures to help ensure that development teams complete all SDLC phase or independent sprint requirements before moving into subsequent phases.
- Control and security features to be designed and built, or acquired, and implemented.
- Change management processes to minimize disruption to the project plan.
- Risk management processes, including project methodology selection.
- Cost tracking mechanisms, including to track overhead (e.g., office space, hardware, and software used during the project) as well as other related costs (e.g., budgeting personnel expenses, outsourced activities).

When evaluating IT project requests, effective management considers input from all stakeholders. For example, management evaluates the appropriateness of the requested functional requirements. Each function has design and development implications. Each function requires testing, documentation, and ongoing support. Therefore, the exclusion of unnecessary functions can significantly reduce the resources required to support a request. Management considers and analyzes all requests to determine whether to develop or acquire the system or component.

¹³⁸ For more information on conducting a security impact analysis, refer to NIST SP 800-128, [*Guide for Security-Focused Configuration Management of Information Systems*](#).

IV.O.1(b) *Development or Acquisition*

During the development or acquisition phase, the system or component is designed and developed or acquired. Key system or component designs are created or reviewed before development begins or the acquisition is completed. When a project is initially proposed and reviewed, the decision to develop or acquire may be uncertain. Early stakeholder involvement in design creation or acquisition specification review mitigates the risk that the system design does not support the functional requirements. The more predictive the SDLC is, the more design work will occur earlier in the SDLC. The more adaptive the SDLC is, the more design work will be spread throughout the SDLC phases.

When an entity acquires a system or component, important design considerations include how much configuration is possible, whether the system or component can be restored to a secure configuration, and whether there are restrictions on users or services that can make configuration changes. Entity personnel can configure systems and components to avoid specific known threats and risks based on the entity's risk appetite. For example, if a product or service is used by bank customers, it may be important that the product or service's security and functionality allows the capability for the customer to change some configurations (e.g., change location restrictions, adjust monetary limits, and allow use of physical access controls).

System and component security should be a high priority throughout this phase. If an IT security risk assessment was conducted as part of the feasibility study, it can be used early in this phase to design baseline controls to address risks identified. If an IT security risk assessment was not completed as part of the feasibility study, it can be completed early in this phase. Designing security controls early in the development and acquisition phase is important to system or component confidentiality, integrity, availability, and resilience. If the system or component is being developed or acquired, it is important to address security concerns, such as those for customer information, and personnel should "identify reasonably foreseeable internal and external threats that could result in unauthorized disclosure, misuse, alteration, or destruction of customer information or customer information systems."¹³⁹ Therefore, it is important to identify security controls requirements and consider appropriate controls that might affect the entire supply chain. It is typical for system and component functionality and design to change throughout the phase, which can change security effectiveness. The security impact analysis performed during the SDLC initiation phase can be helpful to evaluate security adequacy before, during, and after system and component changes are made in this phase.¹⁴⁰ Early implementation

¹³⁹ Refer to [GLBA](#) and 15 USC 6801 and 6805(b), further implemented by FFIEC members as follows: FDIC: 12 CFR 364, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)," and 12 CFR 364, supplement A to appendix B, "[Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice](#);" FRB: Regulation H, 12 CFR 208, appendix D-2, "[Interagency Guidelines Establishing Information Security Standards](#)," and Regulation Y, 12 CFR 225, appendix F, "[Interagency Guidelines Establishing Information Security Standards](#);" NCUA: 12 CFR 748, appendix A, "[Guidelines for Safeguarding Member Information](#)"; OCC: 12 CFR 30, appendix B, "[Interagency Guidelines Establishing Information Security Standards](#)." Additionally, refer to FTC 16 CFR 314, "[Standards for Safeguarding Customer Information](#)," for similar provisions for service providers.

¹⁴⁰ For more information on conducting a security impact analysis, refer to NIST SP 800-128, [Guide for Security-Focused Configuration Management of Information Systems](#).

of security controls can minimize their cost, allow for efficient deployment, and reduce integration issues.

Appropriate personnel should define and create initial testing, conversion, implementation, and training plans and obtain management approval during the development or acquisition phase. Development personnel should initially test the design during development to confirm that the system's or component's functionality is meeting requirements and controls, including security controls, are functioning as intended. Testing early and throughout this phase helps a team identify functional or security flaws when remediation can be less expensive.

The potential for scope creep increases during this phase, and project stakeholders monitor and mitigate this risk. Effective entities have a process to review the appropriateness of new or modified requirements and development changes to minimize scope creep, as discussed in the [“IT Project Management”](#) section of this booklet.

Designers should document completed designs and functions, including information security designs. Design documents may include system architecture, software architecture, and data structure design. Detailed documentation enhances a developer's ability to modify systems and components after they are placed into production. The documentation should include appropriate information such as all related systems and components (including IoT product components and devices), any accreditation, certification, or evaluation results. Documentation can be used by management to compare original objectives and specifications with systems and components ready for implementation. The development team typically drafts user, operator, and maintenance manuals during this phase.

IV.O.1(c) *Implementation and Assessment*

The objective of the implementation and assessment phase is to prepare the system, operational environment, entity, and end users for system or component use, and to assess whether the system or component meets business needs and operational requirements. In this phase, the team configures and enables system or component features, tests the features' functionality, and installs or implements the system or component after obtaining appropriate approvals.

It is important to thoroughly test before implementation to help ensure that the system or component meets all entity specifications. These tests should be documented so that as the system or component is changed, previous tests are used and adjusted to validate rather than creating new tests. Building on original testing documentation also may result in subsequent tests being more comprehensive than if they were not leveraged.

The more complex and critical the development or acquisition, the more important it is to rigorously assess the product before implementation. For example, conversions of core banking systems require more detailed reviews and higher levels of approvals from management given their significance to delivery of business services, as opposed to a lower level of oversight for routine maintenance of a less critical system. These reviews would occur before implementation. In the more complex and critical implementations, approval from many stakeholders such as business continuity management, information security, and third-party risk management may be

necessary. For more information on routine changes and conversions, refer to the “[Implementing Changes](#)” section of this booklet.

Primary implementation phase tasks include communicating the implementation schedule to internal and external stakeholders, training users, and installing the system or component. To be most effective, the implementation schedule takes into account the business impact (e.g., conversions are scheduled on long weekends to allow additional time before affecting weekday business). Management and other appropriate personnel perform tasks such as the following during the implementation phase:

- Execute the implementation plan, including the following:
 - Assessing risk for issues that may occur during implementation activities (e.g., rollout, conversion, or update).
 - Conducting user acceptance testing (UAT).
 - Updating the asset inventory.
 - Training (internal and external).
- Input, import, or convert data and validate the functionality of the system or component using those data.
- Confirm the confidentiality, integrity, availability, and resilience of systems and data.
- Confirm the interoperability of systems and components.
- Configure and test system and component security controls.
- Validate performance parameters (e.g., throughput, capacity, error rates, and memory usage) and ensure that the system or component operates as expected.
- Conduct a final audit of information security and adherence to policies and procedures, as well as risk tolerance levels. Determine whether the findings of the audit meet the entity’s predetermined requirements for system deployment.
- Create and test back-out or rollback plans to prepare for unforeseen and unrecoverable problems that may occur during implementation. Entity personnel may accomplish this by various back-out or rollback methods (e.g., using one or more restart points or reverting to the legacy system or prior version).
- Conduct PIRs (e.g., survey users, review complaints, plan future functionality, and identify other improvements). Additionally, the reviews may identify lessons learned and process improvement information.

Implementation strategies vary and are designed to mitigate different types of implementation risk. Examples of implementation types may include the following:

- **Parallel implementation** consists of running the old and new system or component simultaneously until the new system or component is evaluated and approved. If the new system fails, operations can continue using the old system while issues are corrected. Running two systems or components simultaneously requires additional resources (e.g., costs, personnel, and time), but is a logical strategy if no system downtime is tolerable.
- **Pilot implementation** involves releasing the complete, new system or component to a limited (i.e., pilot) group of users. After successful rollout to that pilot group, management decides how to proceed with the rollout process. Advantages of using a piloting strategy

include minimizing the risks of a comprehensive rollout to the entire user population, as well as opportunities to test the system with the initial rollout and any additional rollouts. However, this strategy may also be time-consuming and expensive. A risk to this strategy is that it may allow for large numbers of insignificant enhancements instead of focusing on critical system issues.

- **Phased implementation** involves deploying a new system or component in phases (i.e., rolling out modules, features, or functionality incrementally over time) generally according to a predetermined schedule. This strategy helps mitigate the risk that a foundational flaw is discovered at the end of the project rather than earlier when it would be easier to correct. This strategy potentially requires less training and fewer resources spent at one time, and potentially fewer errors on which to focus during each phase. This strategy may lengthen the implementation time frame. In addition, there may be integration and interoperability concerns, such as reverse compatibility issues with legacy components while the old system is being replaced in phases.

Training is critical to the success of the implementation and assessment phase as are training plans and supporting materials for operating, using, and maintaining the system. Training is often the first exposure to the system for most users and should be provided before system or component deployment to the production environment. Training enables users to familiarize themselves with the new or updated system or component. A positive training experience typically improves user acceptance. During this phase, appropriate personnel should coordinate training logistics, including who should be trained, what the training involves, and when training should be conducted. Effective management organizes a training and awareness campaign and notifies users of any implementation and training responsibilities. This helps establish user expectations regarding system and component capabilities. Those responsible for supporting the system or component in the entity should have a combination of technical documentation, training, and hands-on assistance enabling support personnel to provide operational support to the users. Once the product is implemented, management should perform a PIR (see the “[Post-Implementation Review](#)” section of this booklet for more information).

IV.O.1(d) *Operations and Maintenance*

In the operations and maintenance phase, systems and components are in production and operating; enhancements and other modifications are developed and tested; and hardware and software components are changed. Entity personnel should continuously monitor system and component performance and adjust the system or component so that it operates consistent with pre-established user, security, and other entity requirements. Entity personnel should manage and document configuration changes whether baseline or unique. Documenting system and component changes and assessing the potential impact of these changes on a system’s or component’s security, functionality, performance, and resilience are essential activities in this phase.

Maintenance can occur periodically or regularly, such as annually, semiannually, quarterly, or weekly. In agile-based methodologies, maintenance may occur continuously. The maintenance frequency varies across systems and components, and the timing is prompted by business and operational need.

An entity's change control processes play an important role in the operations and maintenance phase. Changes to a system or component can affect baseline configurations and controls, and this impact should be analyzed. To mitigate the risk of an enhancement or other modification disrupting or degrading operations, effective entities follow established change management policies, standards, and procedures. For more information, refer to the "[Maintenance](#)" section of this booklet and the *FFIEC IT Handbook's* "[Architecture, Infrastructure, and Operations](#)" and "[Information Security](#)" booklets.

Examples of commonly performed tasks in this phase are the following:

- Ensuring that systems and components are operational and available during the defined hours of operation.
- Implementing nonemergency change requests during scheduled outages.
- Ensuring that all processes, manual and automated, are documented.
- Ensuring adequate resource availability for operations, maintenance, and resilience.
- Performing and testing system, component, and data backups.
- Validating the entity's physical security measures.
- Ensuring that contingency plans for resilience are updated, tested, and funded.
- Ensuring that all operations and maintenance personnel take appropriate, ongoing training.
- Maintaining and monitoring system and component performance measurements, statistics, and system logs.
- Ensuring that third-party SLAs are being monitored and met.
- Performing configuration, security, and design assessments to ensure that system and component parameters and configurations are correct.
- Patching software for systems and components.
- Managing and controlling configurations and changes to the system. This includes installing, configuring, upgrading, and maintaining systems, components, and data, as well as related documentation.

Management is responsible for operations and maintenance phase task performance regardless of whether tasks are performed by entity or third-party personnel. For more information, refer to the *FFIEC IT Handbook's* "[Outsourcing Technology Services](#)," "[Business Continuity Management](#)," "[Architecture, Infrastructure, and Operations](#)," and "[Information Security](#)" booklets.

IV.O.1(e) *Sunset and Disposal*

In the sunset and disposal phase, plans are developed for the orderly termination of systems or components and the preservation of data that reside in them during the transition to a new system or component. Data to be preserved include entity data and client and consumer data. The systems, components, and data may be migrated to another system, archived, reassigned, or destroyed. There are several risks in the disposal phase such as the risk of sensitive data disclosure to unauthorized individuals, business functionality impairment, intellectual property loss, and reputation damage. Archive solutions may address the frequency and speed of any

future data retrieval. Additionally, effective entities have a process in place to periodically validate the accessibility of archived data.

Specific tasks and activities occurring during this phase depend on the risk and complexity of the systems, components, or services. Considerations in system retirement and disposal include the following:

- Disposal or transition plan involving all applicable parties that identifies critical steps, decisions, and milestones to properly terminate, transition, and dispose of a system, component, service, and data.
- Hardware and software components to preserve, including for archive use.
- Data archive and migration—data could be migrated to the new system, archived, or a combination of the two.
- System and component documentation preservation.
- Advanced notification to all end users and stakeholders of the system or component sunset plan and the planned termination date.
- Plans for end-user migration to a replacement system or component.
- Plans for permanently erasing (i.e., sanitizing) data from the terminated system or component. Methods for sanitization include deleting, overwriting, and destroying data.¹⁴¹

If the system or component requiring disposal is managed by or the related data are stored by a third party, comprehensive off-boarding procedures help mitigate risks related to unauthorized access to sensitive information. Procedures should address items such as access, security, data governance and storage, and recordkeeping requirements (e.g., legal, regulatory, compliance, and audit). Effective management has a process to validate that its third party appropriately performs all necessary steps associated with system, component, data, and service sunset and disposal. The third party should maintain and make available to management evidence (e.g., certification) of disposal and archival activities to demonstrate completion.

Effective entities perform a post-sunset and disposal review that confirms the necessary processes were completed and documents lessons learned from shutting down and archiving the terminated system or component. The review should identify archived data and documentation locations. The review may be conducted again within six months of system or component disposal to identify any missed issues that only surface after an extended period of the system or component not being available.

For more information on sunset and disposal, refer to the *FFIEC IT Handbook's* "[Architecture, Infrastructure, and Operations](#)," "[Information Security](#)," and "[Outsourcing Technology Services](#)" booklets.

¹⁴¹ For more information on data sanitization processes, refer to the *FFIEC IT Handbook's* "[Information Security](#)" booklet.

IV.P Third-Party Relationship Risk Management

Entities can realize significant benefits from working with third parties such as gaining access to new technologies, human capital, delivery channels, products, services, and markets. However, the use of third parties can reduce an entity's direct control over activities and may introduce new risks or increase existing risks¹⁴² in development, acquisition, and maintenance activities. Increased risk often arises from greater operational or technological complexity, newer or different types of relationships, or potentially inferior performance by the third party. As part of sound risk management, entities engage in more comprehensive and rigorous planning, due diligence, oversight, and management of third-party relationships that support higher-risk development, acquisition, and maintenance activities, including critical activities. Considerations discussed are relevant to each entity's development, acquisition, and maintenance activities, based on specific facts and circumstances, but may not apply to all of an entity's third-party relationships.

IV.P.1 Planning

As part of sound risk management, effective planning allows an entity to evaluate and consider how to manage risks before entering into a third-party relationship. Higher risk and greater complexity development, acquisition, and maintenance services warrant more careful planning and other considerations to mitigate the risk that the relationship will result in material negative impacts on the entity. Refer to the [Interagency Guidance on Third-Party Relationships: Risk Management](#) and FFIEC IT Handbook's "[Outsourcing Technology Services](#)" booklet for more information on planning concepts.

IV.P.2 Due Diligence and Third-Party Selection

Conducting third-party due diligence¹⁴³ before selecting and entering into relationships is an important part of sound risk management when engaging third parties in development, acquisition, and maintenance activities. Due diligence gives management the information needed to determine whether a relationship would help achieve a banking organization's strategic and financial goals. Third parties that would support an entity's higher risk or more complex development, acquisition, and maintenance activities typically warrant a greater degree of due diligence.

In some instances, the appropriate entity personnel may not be able to obtain the desired initial due diligence information from a third party. For example, the third party may not have a long operational history, may not allow onsite visits, or may not share (or be permitted to share) information that is requested. While the methods and scope of due diligence may differ, the

¹⁴² Refer to the [Interagency Guidance on Third-Party Relationships: Risk Management](#).

¹⁴³ Merriam-Webster defines "[due diligence](#)" as "the care that a prudent person might be expected to exercise in the examination and evaluation of risks affecting a business transaction." Due diligence includes assessing the third party's ability to perform the activity as expected, adhere to an entity's policies related to the activity, comply with all applicable laws and regulations, and conduct the activity appropriately.

entity's project management process should identify and document any limitations, understand the risks of such limitations, and consider potential alternatives.¹⁴⁴ Management should evaluate the conclusions from such supplemental efforts based on the entity's own specific circumstances and performance criteria for the activity. Refer to the [Interagency Guidance on Third-Party Relationships: Risk Management](#) and FFIEC IT Handbook's "[Outsourcing Technology Services](#)" booklet for more information on due diligence concepts.

IV.P.3 Contract Negotiation

When evaluating whether to enter into a relationship with a third party, an entity's management typically determines whether a written contract is needed; and, if the proposed contract can meet the entity's business goals and risk management needs, then entity management typically negotiates appropriate contract provisions¹⁴⁵ for development, acquisition, and maintenance activities. In certain circumstances, it may be advantageous to negotiate initial development, acquisition, and maintenance contracts with other organizations (e.g., banking associations or user groups). As part of its oversight responsibilities, the board should be aware of—and, as appropriate, may approve or delegate approval of—contracts involving higher-risk development, acquisition, and maintenance activities. Refer to the [Interagency Guidance on Third-Party Relationships: Risk Management](#) and FFIEC IT Handbook's "[Outsourcing Technology Services](#)" booklet for more information on contract negotiation concepts.

IV.Q Supply Chain Considerations

Action Summary

Management should implement SCRM policies and procedures consistent with the entity's size, criticality to the financial system, and complexity.

Examiners should review the following:

- Relevant policies, standards, procedures, project plans, and any SDLC documentation to determine how the examined entity has incorporated SCRM into its enterprise-wide risk management practices.
- System and component control configurations and reports used by management to monitor, control, and protect communications at the key access points of information systems that inform SCRM activities.
- Entity's architectural designs, system and component development techniques, and systems engineering principles as well as those applicable to the entity's third parties to maintain effective information security throughout the supply chain.

¹⁴⁴ Refer to the [Interagency Guidance on Third-Party Relationships: Risk Management](#).

¹⁴⁵ [Ibid.](#)